7-ELEVEN ATTACK ANALYSIS

When Trust Is the Vulnerability

The 2026 7-Eleven franchisee data breach and the ShinyHunters Salesforce data-theft campaign (UNC6040 / UNC6240)

Threat model · Root cause · Severity · Mitigation
STRIDE · OWASP Threat Dragon · MITRE CWE / CAPEC / ATT&CK · CVSS v4.0

Prepared by: Harjot Sidhu and Mehakpreet Thind

Cybersecurity Threat Analysis · 2026

Table of Contents

1. Executive Summary 3
2. Incident Overview 4
3. Incident Timeline (2026) 4
4. Scope and Data Exposed 5
5. Threat Actor and Attribution 5
6. Attack Vector and Attack Chain 6
6.1 The attack chain 6
6.2 Why traditional defenses did not catch it 6
7. Threat Model (STRIDE) 6
8. Root Cause and Weakness Mapping (CWE) 8
8.1 Root cause summary 8
8.2 CWE mapping 8
9. Attack Pattern Mapping (CAPEC and ATT&CK) 8
10. CVE Status and Severity (CVSS v4.0) 9
11. Response and Remediation 10
11.1 Recommended controls 10
12. Broader Campaign Context 11
13. References 11

1. Executive Summary

In April 2026, 7-Eleven, Inc. disclosed that an unauthorized third party accessed internal systems holding franchisee application records. The company says the only firm date in the official record is April 8, 2026, the point at which the intrusion into systems storing franchisee documents was identified. Notification letters went to affected individuals on May 1, 2026, signed by Chief Information Security Officer Jim Kastle, and the incident was filed with state regulators in Maine, Massachusetts, and Vermont on May 15 and 16, 2026.

The exposed records came from information that current, former, and prospective franchisees had submitted during the franchise application process. Confirmed data elements include names, dates of birth, physical addresses, phone numbers, and email addresses, and the Massachusetts regulatory filing further confirmed that Social Security numbers and driver's license numbers were involved. Have I Been Pwned lists roughly 185,300 affected accounts. 7-Eleven has not published an official total and has stated it has no reason to believe customer data was affected.

The extortion group ShinyHunters claimed responsibility on April 17, 2026, saying it had taken more than 600,000 records from 7-Eleven's Salesforce environment. After 7-Eleven declined to pay, the group published a 9.4 GB archive of stolen files on its dark-web leak site. 7-Eleven has not officially named any actor, so the attribution here is based on the group's own claim and on analysis of the wider campaign.

No software defect was exploited, so there is **no governing CVE**. Salesforce, Google, and Mandiant have all said the wider campaign did not rely on a flaw in the Salesforce platform. The attackers instead abused a legitimate feature, the OAuth connected-app authorization flow, after tricking an employee through social engineering. Because the failure was in human trust and authorization settings, this report describes the weakness using CWE, CAPEC, and ATT&CK and explains why no CVE fits.

2. Incident Overview

7-Eleven runs most of its U.S. stores through franchisees rather than owning them directly. Its franchise-application files therefore hold identity documents for a large number of applicants in one place, which is what made them a valuable target.

According to the company's own description, the affected systems were "certain 7-Eleven systems used to store franchisee documents." The documents contained information provided during the franchise application process. The company engaged a leading forensic security firm, states that it has remediated the incident, and is offering affected individuals up to 24 months of complimentary identity-theft protection and CyberScan credit monitoring through IDX.

Two different numbers describe the scale, and they measure different things. The state filings list only about 50 affected franchisees in total across Massachusetts, Maine, and Vermont, because each state filing counts only that state's own residents. The widely reported figure of roughly 185,000 comes from Have I Been Pwned, which catalogued the full leaked dataset. 7-Eleven has confirmed neither a total count nor the attacker's claim of more than 600,000 records, and describes the impact only as a limited number of current, former, and prospective franchisees.

3. Incident Timeline (2026)

Date	Event
Spring 2026	Unauthorized access to systems storing franchisee documents begins. No exact intrusion date was publicly disclosed; activity may have started slightly before April 8.
April 8, 2026	The only specific date in the official record. 7-Eleven identifies that an unauthorized third party gained access to systems used to store franchisee documents.
April 17, 2026	ShinyHunters claims responsibility (attacker claim, not officially confirmed by 7-Eleven).
Late April 2026	After 7-Eleven declines to pay, ShinyHunters publishes a 9.4 GB archive of stolen files, including Social Security numbers and driver's licenses, on its dark-web leak site (about two weeks after the activity surfaced).
May 1, 2026	7-Eleven sends breach-notification letters to affected individuals, signed by CISO Jim Kastle.
May 15–16, 2026	Incident filed with the Attorneys General of Maine, Massachusetts, and Vermont as a notice of security incident, categorized as a hacking / IT incident. The Massachusetts filing confirms Social Security numbers and driver's licenses.
May 24, 2026	Breach added to Have I Been Pwned, which lists about 185,300 affected accounts.
Post-disclosure	7-Eleven engages a forensic firm, states the incident is remediated, and offers 24 months of IDX identity-theft protection and CyberScan credit monitoring.

Only April 8, 2026 is confirmed by 7-Eleven as a specific date. The remaining dates are reconstructed from regulatory filings, breach-notification letters, the Have I Been Pwned listing, and the attacker's own claim.

4. Scope and Data Exposed

The exposed records originated from 7-Eleven franchise application files. Drawing the official notifications, the state regulatory filings, and the Have I Been Pwned listing together, the confirmed data elements are:

- Names
- Dates of birth
- Physical addresses
- Phone numbers
- Email addresses
- Social Security numbers (confirmed in the Massachusetts Attorney General filing)
- Driver's license numbers (confirmed in the Massachusetts Attorney General filing)

A record that combines name, date of birth, address, Social Security number, and driver's license is far more damaging than contact details on their own, because it gives an identity thief most of what is needed to impersonate someone. 7-Eleven has said it has no reason to believe general customer data was affected; the exposure is limited to franchise applicants.

5. Threat Actor and Attribution

7-Eleven has not said who carried out the attack. Attribution here comes from two sources: the group's own public claim, and security-researcher analysis linking the incident to a known campaign. Both are treated as claims rather than as company confirmation.

The actor is ShinyHunters, a financially motivated extortion group. Google's Threat Intelligence Group and Mandiant track the associated activity as two clusters: UNC6040 for the initial access (the vishing and OAuth-grant phase) and UNC6240 for the extortion phase (the pay-or-leak demand under the ShinyHunters brand). The motive is financial. Ransom payment is demanded in Bitcoin, and when payment is refused the group follows through on its leak threat, as it did here with the 9.4 GB archive.

Cluster	Role	Activity in this incident
UNC6040	Initial access	Vishing and device-code OAuth grant to obtain an access token
UNC6240	Extortion	Pay-or-leak demand paid in Bitcoin; ShinyHunters branding
Outcome	Threat carried out	9.4 GB stolen archive published on the dark web after refusal to pay

6. Attack Vector and Attack Chain

7-Eleven has not confirmed exactly how its own breach happened. The chain described below is the method documented for the wider ShinyHunters Salesforce campaign, applied here because the attacker claimed it had breached 7-Eleven's Salesforce environment. For this type of attack, reporting points to how organizations configure connected-app access and permissions as the weak spot, rather than to any flaw in Salesforce itself.

6.1 The attack chain

#	Step	Description
1	**Reconnaissance**	Attackers profile the organization and identify employees who have CRM access.
2	**Vishing call**	A phone call impersonating IT support to gain the employee's trust and pressure them to act quickly.
3	**Device-code OAuth grant**	The employee is guided to Salesforce's connected-app authorization page and enters an attacker-supplied code, which issues an access token to the attacker's tooling.
4	**Over-permissioned app**	The rogue connected app (a modified "Data Loader") is granted broad API scopes, including full read and export.
5	**Bulk exfiltration**	The attacker queries and bulk-exports the franchisee / CRM data over the authorized token.
6	**Delayed extortion**	Weeks later, a Bitcoin ransom demand arrives with a leak threat, carried out as the 9.4 GB dump.

6.2 Why traditional defenses did not catch it

Because the export went out over a legitimate, attacker-authorized OAuth token, it bypassed the usual perimeter and password controls. There was no software flaw for vulnerability management to flag, the API calls looked authenticated and well-formed to intrusion-detection systems and web-application firewalls, and there was no scanning or exploit activity for external telemetry to pick up. To the tools watching the environment, the traffic looked like normal authorized use of the platform.

7. Threat Model (STRIDE)

A data-flow model was built in OWASP Threat Dragon and analyzed with STRIDE. The relevant assets are the CRM personally identifiable information (names, addresses, Social Security numbers, driver's licenses), the OAuth access token, and the audit logs. The entry points are the help-desk employee, the Salesforce device-code authorization page, and the REST / Bulk API. The key trust boundary is the line between the public internet and staff, which the issued token crosses to reach tenant data.

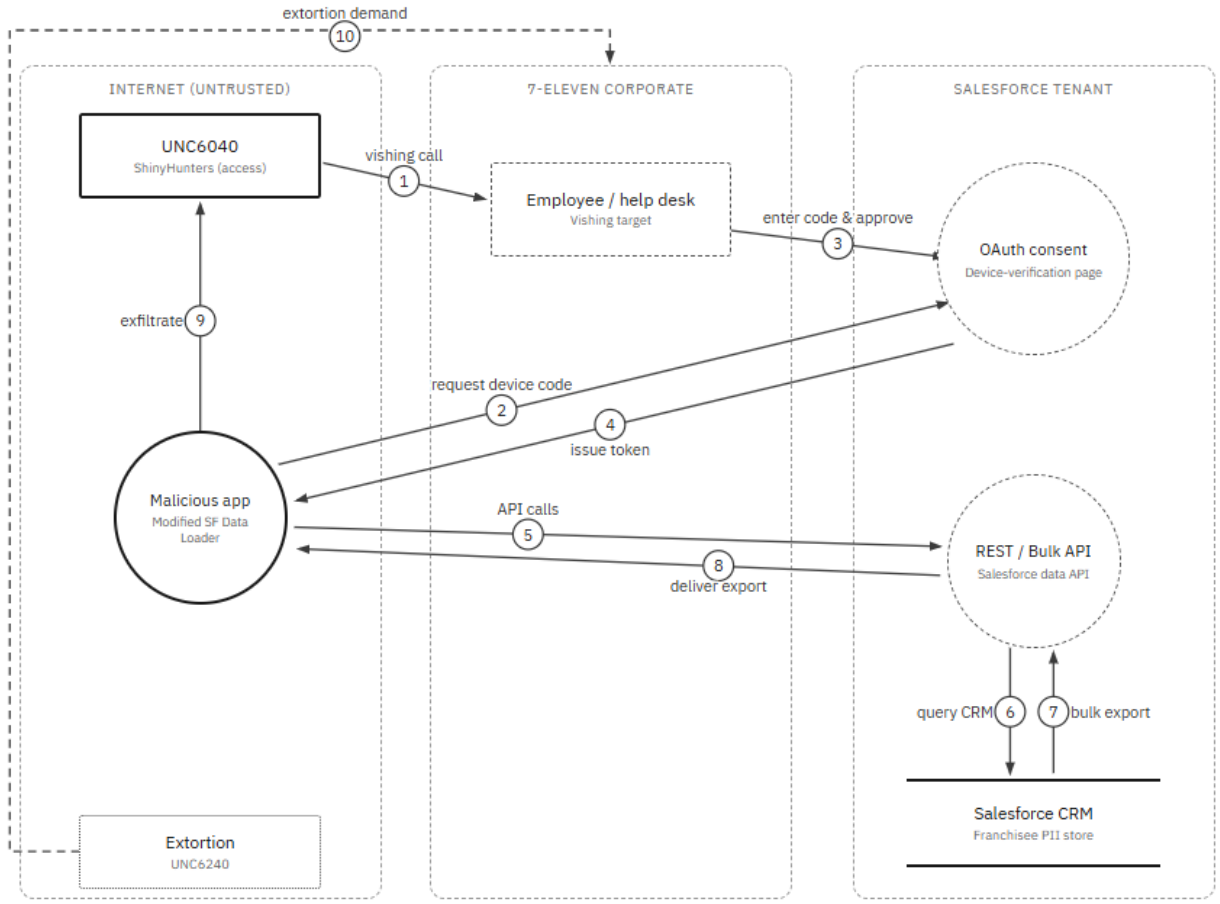


Figure 1. STRIDE data-flow model (OWASP Threat Dragon). Trust boundaries: Internet (untrusted), 7-Eleven Corporate, and Salesforce Tenant. Threat actors: UNC6040 (access), UNC6240 (extortion), and the malicious Data Loader. Numbered flows 1 to 10 trace the attack from the vishing call through device-code approval, token issuance, bulk export, exfiltration, and the extortion demand.

STRIDE category	Assessment in this incident	Risk
Spoofing	Vishing impersonation of IT support; a rogue Data Loader authorized through the device-code grant.	**High**
Tampering	Not observed. The objective was data theft, not modification.	Low
Repudiation	No IP or anomaly checks were in place to attribute the token misuse.	**Medium**
Information Disclosure	Bulk export of regulated PII over an attacker-authorized token. This was the attacker's main objective and the largest impact.	**Critical**
Denial of Service	Out of scope. The objective was theft, not disruption.	Low
Elevation of Privilege	The device-code approval proves possession of a code, not the actor's identity; the connected app was over-scoped.	**High**

Most critical risk: the bulk export of regulated PII. Because it used a legitimate, attacker-authorized token, it got past perimeter and password controls, no least-privilege scoping or IP restriction was in place to stop it, and once the data left the tenant it could not be recovered.

8. Root Cause and Weakness Mapping (CWE)

The breach was not caused by a software vulnerability. It came from abuse of a legitimate feature, the OAuth connected-app authorization flow, set up through social engineering. Salesforce stated publicly that the campaign did not involve or originate from any vulnerability in its platform. With no platform flaw, no CVE applies, and the weakness has to be described using CWE categories, which cover classes of weakness rather than specific cataloged defects.

8.1 Root cause summary

The core problem was that a trust decision was left to a person, and the authorization step only checked that someone held a valid code, not that the person was who they claimed to be. Three weaknesses made the outcome worse: the connected app was not scoped to least privilege, there was little governance over which connected apps could be approved, and there were no IP restrictions that might have flagged the unusual token use.

8.2 CWE mapping

The observed failure points were mapped to the following CWE categories. This is the team's analytical mapping; MITRE did not assign these to the 7-Eleven incident directly.

CWE	Name	Why it fits
CWE-1390	**Weak Authentication (primary)**	The authentication mechanism did not sufficiently prove that the claimed identity was correct. The device-code approval verified a code, not the actor. This is the single best fit.
CWE-287	Improper Authentication	The parent / umbrella category for the weakness above.
CWE-269	Improper Privilege Management	The connected app received excessive OAuth scopes; least privilege was not enforced.
CWE-862	Missing Authorization	No secondary control gated the bulk export once the app was authorized.
CWE-522	Insufficiently Protected Credentials	The OAuth token works as a long-lasting credential and was handed straight to the attacker.

9. Attack Pattern Mapping (CAPEC and ATT&CK)

CWE catalogs software weaknesses, so the human side of the attack is mapped to CAPEC (attack patterns) and to MITRE ATT&CK (adversary techniques) instead. Each documented step is matched to the framework entry whose definition it satisfies.

Behavior	CAPEC	MITRE ATT&CK
Pretexting (parent)	CAPEC-407 Pretexting	N/A
IT-support impersonation	CAPEC-413 Pretexting via Tech Support	T1656 Impersonation (supporting)
Voice phishing channel	CAPEC-415 Pretexting via Phone	T1566.004 Spearphishing Voice
Malicious OAuth app obtains token	OAuth / device-code consent phishing	T1528 Steal Application Access Token

The IT-support impersonation matches CAPEC-413; the phone delivery matches CAPEC-415 and ATT&CK T1566.004; and the rogue OAuth app obtaining an access token matches ATT&CK T1528, which explicitly covers consent and device-code phishing. These techniques are documented by Google's Threat Intelligence Group, Mandiant, and Salesforce for this campaign. We applied that campaign's known techniques to this incident as our own analysis; MITRE has not assigned them to 7-Eleven directly.

10. CVE Status and Severity (CVSS v4.0)

No CVE applies. The CVE system and the National Vulnerability Database track software defects, and there is no software defect here. The attack relied on misplaced trust in a connected app and on the employee who approved it, so there is no flaw to assign an identifier to and nothing to patch.

Severity was still estimated with CVSS v4.0 to put the impact in a standard form. The metric choices match how the attack actually worked: it reached the data over the network through the Salesforce API and OAuth endpoints; the attacker held no account and instead used the connected app's delegated identity; the impact was a full export of confidential data with no modification and no confirmed downstream compromise; and the attack required an active human action, namely the employee approving the device code.

Metric	Value	Rationale
Attack Vector (AV)	Network	Exploited over the Salesforce API and OAuth endpoints.
Attack Complexity (AC)	Low	No specialized conditions beyond the social-engineering step.
Privileges Required (PR)	None	The attacker holds no account and rides the app's delegated identity.
User Interaction (UI)	Active	The employee must actively approve the device-code grant.
Confidentiality (VC)	High	Full export of regulated CRM records (names, SSN, DL).

Metric	Value	Rationale
Integrity / Availability (VI, VA, SC, SI, SA)	None	Pure exfiltration; no data modified and no documented downstream impact.

Vector string: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

Derived base score: 6.9 (Medium). This score was calculated with the NIST CVSS v4.0 calculator, not taken from a published advisory. The same vector without required user interaction (UI:N) would score 8.7 (High). The difference matters here because the attack genuinely depends on an employee actively approving the grant, which makes Medium the more honest rating. The score is an estimate of impact and does not replace a CVE, since none applies.

11. Response and Remediation

Party / action	What happened
7-Eleven: investigation	Engaged a leading forensic security firm and states the incident has been remediated.
7-Eleven: refused to pay	Declining the ransom is what led ShinyHunters to publish the 9.4 GB archive. This is consistent with FBI guidance that paying offers no guarantee that stolen data is destroyed or kept offline.
7-Eleven: victim support	Notified affected individuals (letter signed by CISO Jim Kastle) and offered 24 months of IDX identity-theft protection and CyberScan credit monitoring.
Salesforce: platform statement	Stated publicly that the campaign did not involve or originate from any vulnerability in its platform.

11.1 Recommended controls

The weaknesses identified above point to specific preventive controls for this class of trust-abuse attack:

- **Connected-app allow-listing and governance:** approve only vetted connected apps and block unmanaged ones such as a rogue Data Loader.
- **Least-privilege OAuth scopes:** restrict API and export scopes so that a single authorization cannot bulk-export an entire dataset.
- **IP and location restrictions on token use:** constrain where issued tokens can be used so anomalous exports are blocked or flagged.
- **Anti-vishing training and verification call-backs:** give staff a defined, out-of-band way to verify IT-support requests before approving any authorization code.
- **Monitoring for bulk export anomalies:** alert on unusual volumes of API or Bulk API export activity even when the calls are authenticated.

12. Broader Campaign Context

The 7-Eleven incident is one instance of a repeatable playbook against high-value SaaS environments reachable through stolen trust rather than exploited code. Related activity in the same family includes:

- **Salesloft Drift:** stolen OAuth tokens (UNC6395) affecting more than 700 organizations.
- **Gainsight:** connected-app token abuse across more than 200 instances.
- **Salesforce data theft:** bulk data theft across Salesforce orgs through abused authorization rather than platform flaws.
- **Renewed vishing:** follow-on campaigns targeting single sign-on, SharePoint, and OneDrive, and an emerging ransomware-as-a-service effort under the group's brand.

All of these cases follow the same pattern as 7-Eleven: the attacker obtains legitimate authorization by deceiving someone, then uses it to export data in bulk. Defending against it depends on controlling which apps are trusted and limiting what each one can access, which is a governance problem more than a patching one.

13. References

[1] BleepingComputer, "7-Eleven data breach exposes personal information of 185,000 people." https://www.bleepingcomputer.com/news/security/7-eleven-data-breach-exposes-personal-information-of-185-000-people/

[2] The Cyber Express, "7-Eleven data breach exposes information." https://thecyberexpress.com/7-eleven-data-breach-exposes-information/

[3] Cybersecurity Dive, "7-Eleven cyberattack, franchisee data." https://www.cybersecuritydive.com/news/7-eleven-cyberattack-franchisee-data/820698/

[4] Help Net Security, "Personal information of 185,000 people exposed after cyberattack on 7-Eleven." https://www.helpnetsecurity.com/2026/05/26/7-eleven-data-breach-shinyhunters/

[5] TechCrunch, "7-Eleven data breach affects over 185,000 people's personal data." https://techcrunch.com/2026/05/26/7-eleven-data-breach-affects-over-185000-peoples-personal-data/

[6] Cybernews, "185,000 affected in 7-Eleven data breach linked to ShinyHunters." https://cybernews.com/security/185000-affected-in-7-eleven-data-breach/

[7] CSP Daily News, "7-Eleven data breach affects 50 franchisees in 3 states" (Maine, Massachusetts, Vermont filings). https://www.cspdailynews.com/company-news/7-eleven-data-breach-affects-50-franchisees-3-states

[8] Mitiga, "ShinyHunters and UNC6395: inside the Salesforce and Salesloft breaches." https://www.mitiga.io/blog/shinyhunters-and-unc6395-inside-the-salesforce-and-salesloft-breaches

[9] Varonis, Salesforce vishing threat (UNC6040). https://www.varonis.com/blog

[10] Push Security, OAuth / connected-app supply-chain abuse analysis. https://pushsecurity.com/blog/analyzing-the-instructure-breach

[11] Google Threat Intelligence Group / Mandiant, UNC6040 and UNC6240 campaign reporting. https://cloud.google.com/blog/topics/threat-intelligence

[12] MITRE CWE (Common Weakness Enumeration). https://cwe.mitre.org/

[13] MITRE CAPEC (Common Attack Pattern Enumeration and Classification). https://capec.mitre.org/

[14] MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge). https://attack.mitre.org/

[15] FIRST / NIST CVSS v4.0 calculator and specification. https://nvd.nist.gov/vuln-metrics/cvss/v4-calculator

Note: 7-Eleven has not officially attributed the breach to any actor and has not confirmed the attacker's record count. Attribution and the technical attack chain in this report are analytical, based on the group's claim and on security-researcher reporting of the wider campaign.